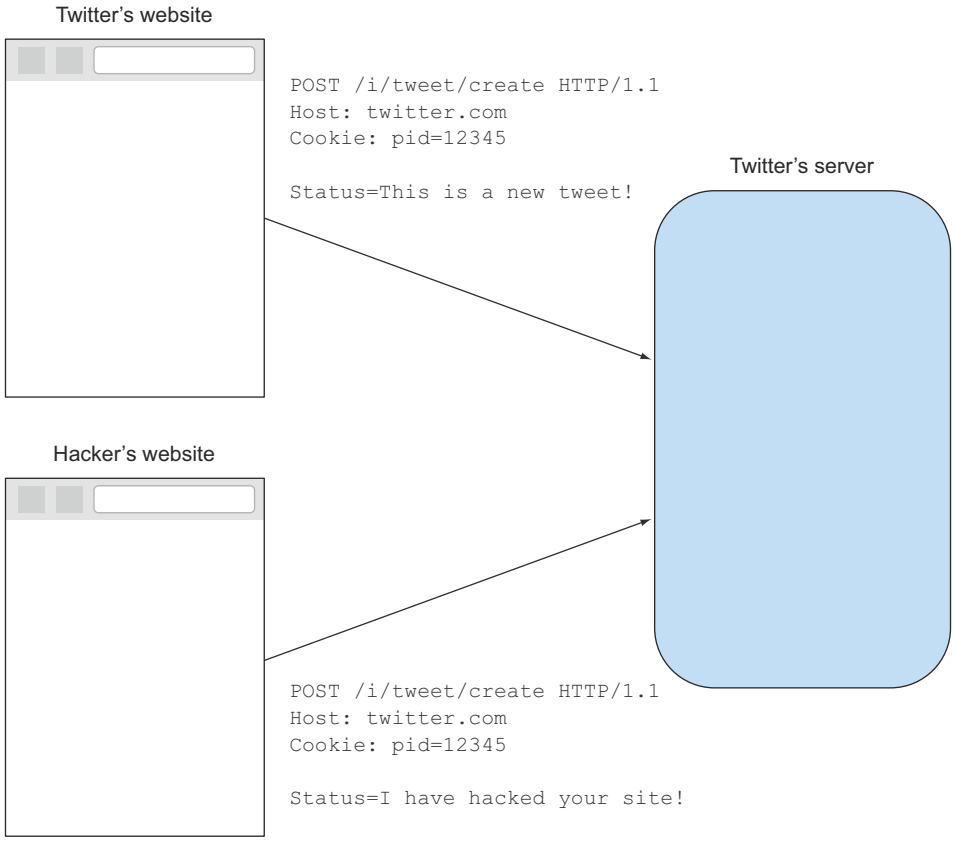


Figure C.1 CSRF exists because cookies are always included on requests, regardless of where the request comes from Luckily Twitter protects itself from CSRF with an authenticity_token..

Along with things like the text of the tweet, the request includes an `authenticity_token`. This token is an encrypted string that Twitter uses to verify that the request is coming from Twitter's own servers, and not from someone else. If Twitter receives a request without this `authenticity_token` (or with an invalid token), the request will fail.

Twitter's `authenticity_token` is an example of a CSRF token. A CSRF token is a server-generated, cryptographically secure token that's included on requests to verify that the request comes from a trusted server. It's similar to the origin header in that it helps validate where the request originates from, but because the CSRF token is cryptographically secure, it can't be generated by anyone but Twitter. This ensures that a request to create a new tweet comes only from Twitter's own web page.

Figure C.3 shows the lifecycle of Twitter's `authenticity_token`. When you first make a request to Twitter, its server generates a unique `authenticity_token` and includes it as a hidden form field in the HTML response. Next, when you compose a new tweet and click the Tweet button, the text of the new tweet and the